Cryptography and Network Security (BT14503)

Dr. Shivangi Shukla
Assistant Professor
Computer Science and Engineering
IIIT Pune



Outline

- Motivation
- Definition
- Security Goals
- Security Attacks
- Security Services
- Security Mechanisms

Why Security?

- User A transmits a file to user B.
  - sensitive information
    - User C
      - not authorized
      - read the file,
      - is able to monitor the transmission and capture copy of the file during its transmission

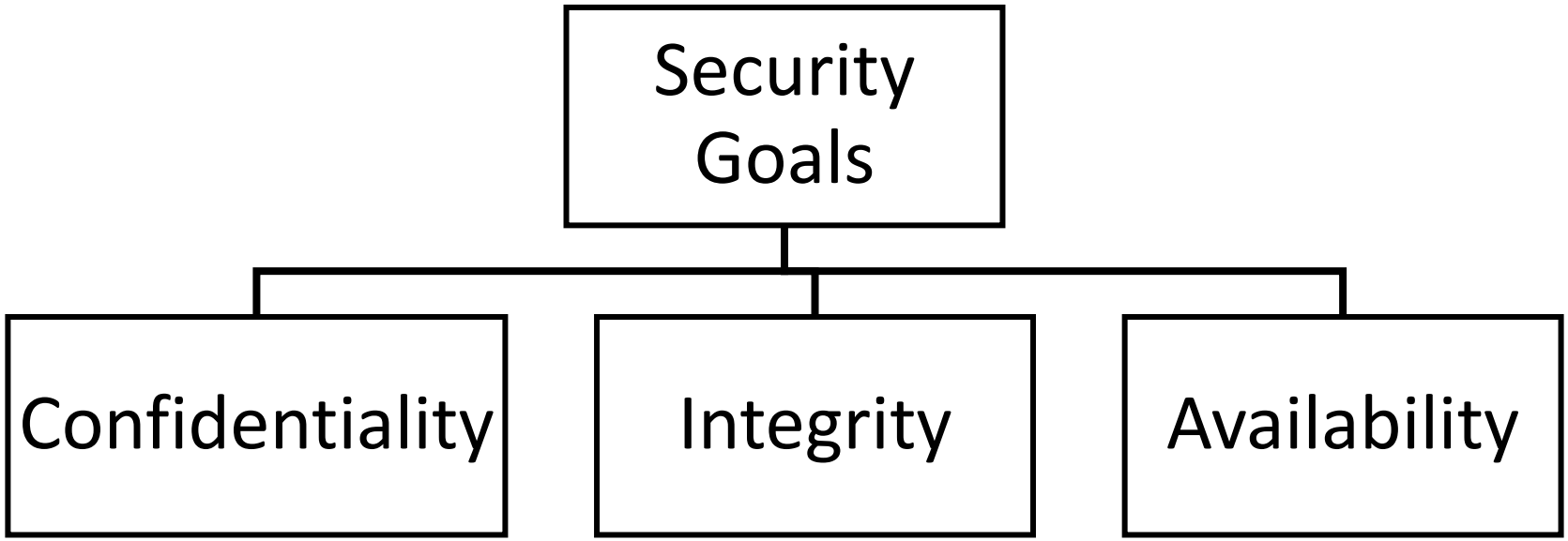
Why Security?..

- Network manager D, transmits message to computer E
  - to update an authorization file to include the identities of a number of new users who are to be given access to that computer.
    - User F
      - intercepts the message,
        - alters its contents to add or delete entries, and then forwards to E,
          - which accepts the message as coming from manager D and updates its authorization file accordingly.

Definition of Computer Security

- The protection afforded to an automated information system in order to attain the applicable objectives of preserving the integrity, availability and confidentiality of information system resources [NIST Computer Security Handbook, 95]

Security Goals (CIA Triad)



Security Goals

- The NIST *Standards for Security Categorization of Federal Information and Information Systems* (FIPS 199) lists confidentiality, integrity, and availability as the three security objectives for information and for information systems.
  - Integrity
    - Data Integrity
    - System Integrity
  - Availability
  - Confidentiality
    - Data Confidentiality
    - Privacy

Security Goals..

- Confidentiality
  - Preserving authorized restrictions on information access and disclosure
    - protecting personal privacy and proprietary information
  - Data Confidentiality
    - private or confidential information is not made available or disclosed to unauthorized individuals
  - Privacy
    - individuals' control or influence what related to them may be collected and stored
      - and by whom and to whom that information may be disclosed.

Security Goals..

- Integrity
  - Guarding against improper modification or destruction of information and system.
  - Data Integrity
    - data (both stored and in transmitted packets) and programs are changed only in a specified and authorized manner.
  - System Integrity
    - system performs its intended function in an unimpaired manner, free from deliberate or inadvertent unauthorized manipulation of the system.
- Availability
  - Assures that systems work promptly and service is not denied to authorized users
  - Assures timely and reliable access to and use of information.

Security Goals..

- CIA triad to define security objectives is well established, some in the security field feel that additional concepts are needed to present:
  - Authenticity
  - Accountability

Security Goals..

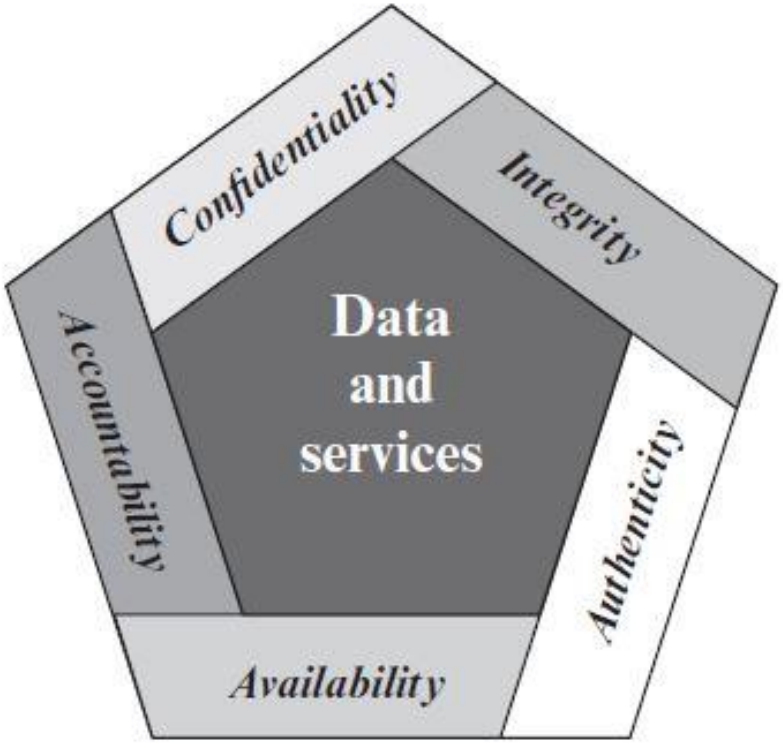


Fig 1: Essential Network and Computer Security Goals

Impact of Security Breach

- Levels of impact on an organization due to security breach
  - Low : Limited adverse effect on organizational operations, organizational assets and individuals
  - Moderate: Serious adverse effect.
  - High : Catastrophic adverse effect.
- Examples
  - Student Grade Information in University
  - Patient's allergy information in Hospital
  - Website that offers forum to registered users to discuss some specific topic
- Anonymous online polls for news channels
  - website is unavailable

Impact of Security Breach..

Low (limited adverse effect)	Moderate (serious adverse effect)	High (catastrophic adverse effect)
organization is able to perform its primary functions, but the effectiveness of the functions is noticeably reduced	significant degradation in mission capability to an extent and duration that the organization is able to perform its primary functions, but the effectiveness of the functions is significantly reduced	severe degradation in or loss of mission capability to an extent and duration that the organization is not able to perform one or more of its primary functions
minor damage to organizational assets or minor financial loss	significant damage to organizational assets or significant financial loss	major damage to organizational assets or major financial loss

OSI Security Architecture

- ITU-T (International Telecommunication Union (ITU) Telecommunication Standardization Sector (ITU-T)) Recommendation
  - X.800 *Security Architecture for OSI*
    - defines security services and mechanisms within the Open Systems Interconnection (OSI) model.

Some Terminologies

- Security attack
  - Any action that compromises security of information owned by an organization
- Security mechanism
  - Process (or device incorporating that process) designed to detect, prevent or recover from security attack
- Security service
  - Intended to counter security attacks and use one or more security mechanisms to provide service

Some Terminologies..

- Threat
  - Potential for violation of security that could breach security
  - Possible danger that exploit vulnerability
- Attack
  - Assault on system security to evade security services and violate security policy of system

However, the terms attack and threat are used interchangeably in literature

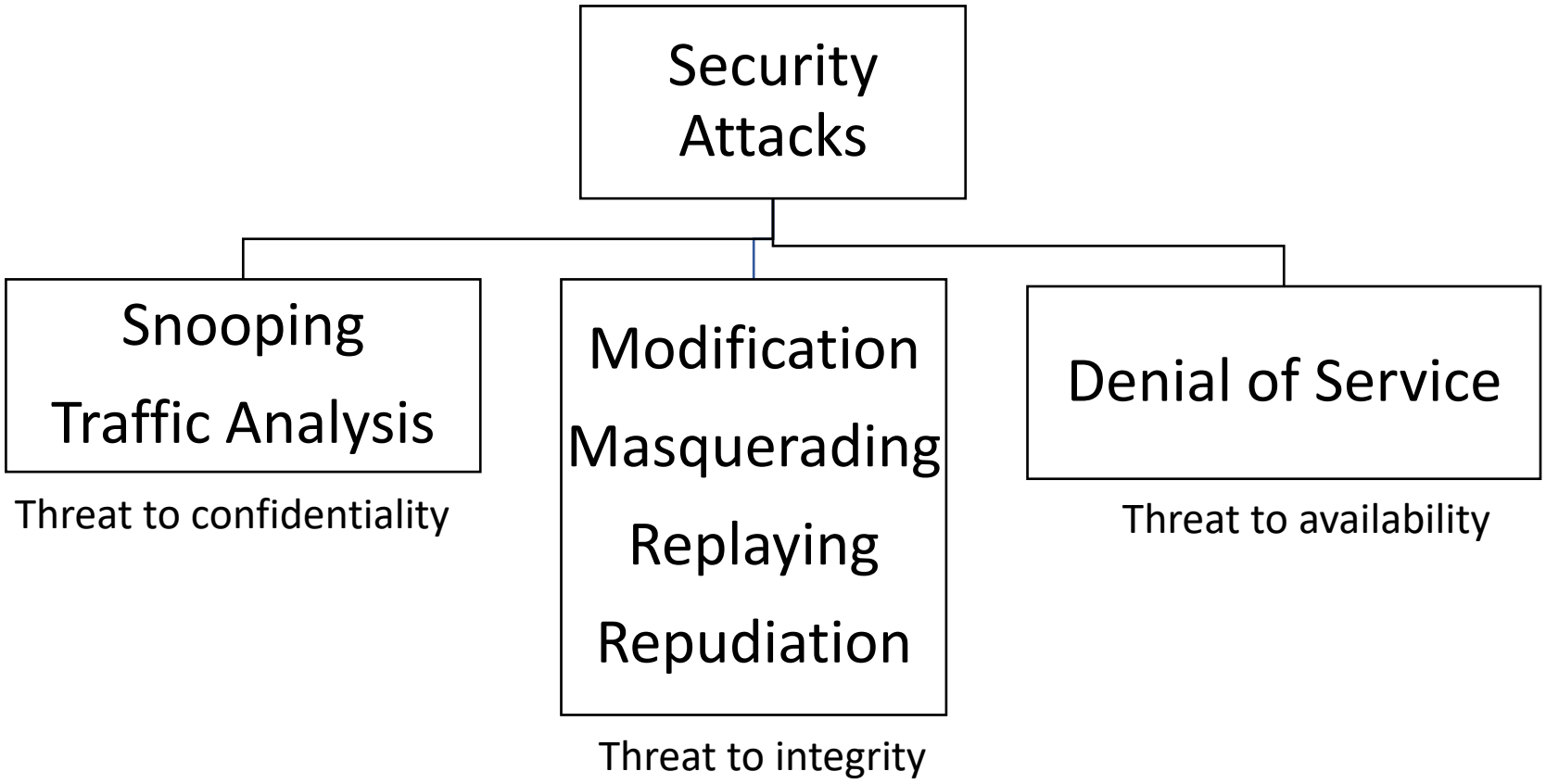
Security Attacks

- Cryptanalytic Attacks
  - These attacks are combination of statistical and algebraic techniques aimed at ascertaining the secret key of a cipher.
  - Ideally all cryptographic algorithms act upon the message distribution and convert it using the key to a ciphertext distribution which looks random.
  - The goal of an attacker is to find properties of the cipher which does not exist in a random function with an aim to mount an attacks faster than the brute force attack.

Security Attacks..

- Non-cryptanalytic Attacks
  - Do not exploit the mathematical weakness of the cryptographic algorithm
  - The three goals of security i.e. confidentiality, integrity, and availability can be threatened by security attacks.

Security Attacks..



Security Attacks..

- Attacks threatening confidentiality
  - Snooping refers to unauthorized access to or interception of data.
    - For example, an unauthorized access to file containing sensitive information
  - Traffic analysis refers to obtaining some other type of information by monitoring online traffic.
    - For example, electronic address of sender and receiver, pairs of addresses to guess nature of transaction

Security Attacks..

- Attacks threatening Integrity
  - Modification means that the attacker intercepts the message and changes it.
    - For example, customer sends message to bank to request for certain kind of transaction. Attacker modifies type of transaction to benefit himself.
  - Masquerading or spoofing happens when the attacker impersonates somebody else.
    - For example, steal PIN of bank customer and pretend to be someone else.

Security Attacks..

- Attacks threatening Integrity
  - Replaying means the attacker obtains a copy of a message sent by a user and later tries to replay it.
    - For example, attacker intercepts previous bank requests send to customer, sends again to receive another payment
  - Repudiation means that sender of the message might later deny that she has sent the message; the receiver of the message might later deny that he has received the message.
    - For example, denial of sender – bank customer requests her bank to send money to third party but later denies from request
    - Denial of receiver – person purchases product from manufacturer, pays electronically, but manufacturer denies regarding receiving from payment.

Security Attacks..

- Attacks threatening Availability
  - Denial of service (DoS) is a very common attack.
    - It may slow down or totally interrupt the service of a system.
    - For example, attacker sends several bogus requests to server and server crashes due to heavy load.

Security Attacks

- Passive Attacks
  - Obtain information
  - Does not modify or harm the system.
    - system continues with its normal operation
  - May harm sender or receiver
- Active Attacks
  - Change the data or harm the system

Which attack is difficult to detect?
Which attack is difficult to prevent?

Security Attacks..

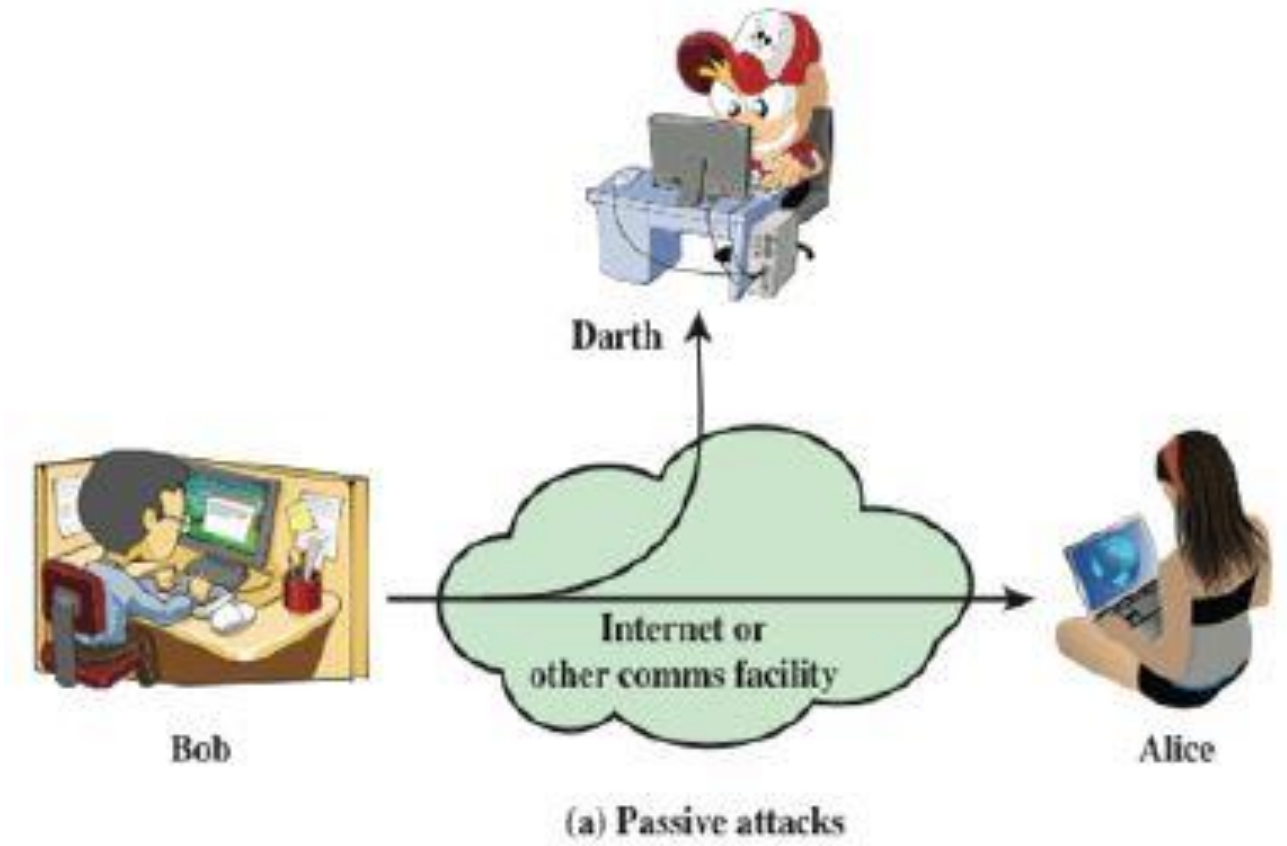


Fig 2: Security Attacks (Courtesy: Cryptography and Network Security by William Stallings)

Security Attacks..

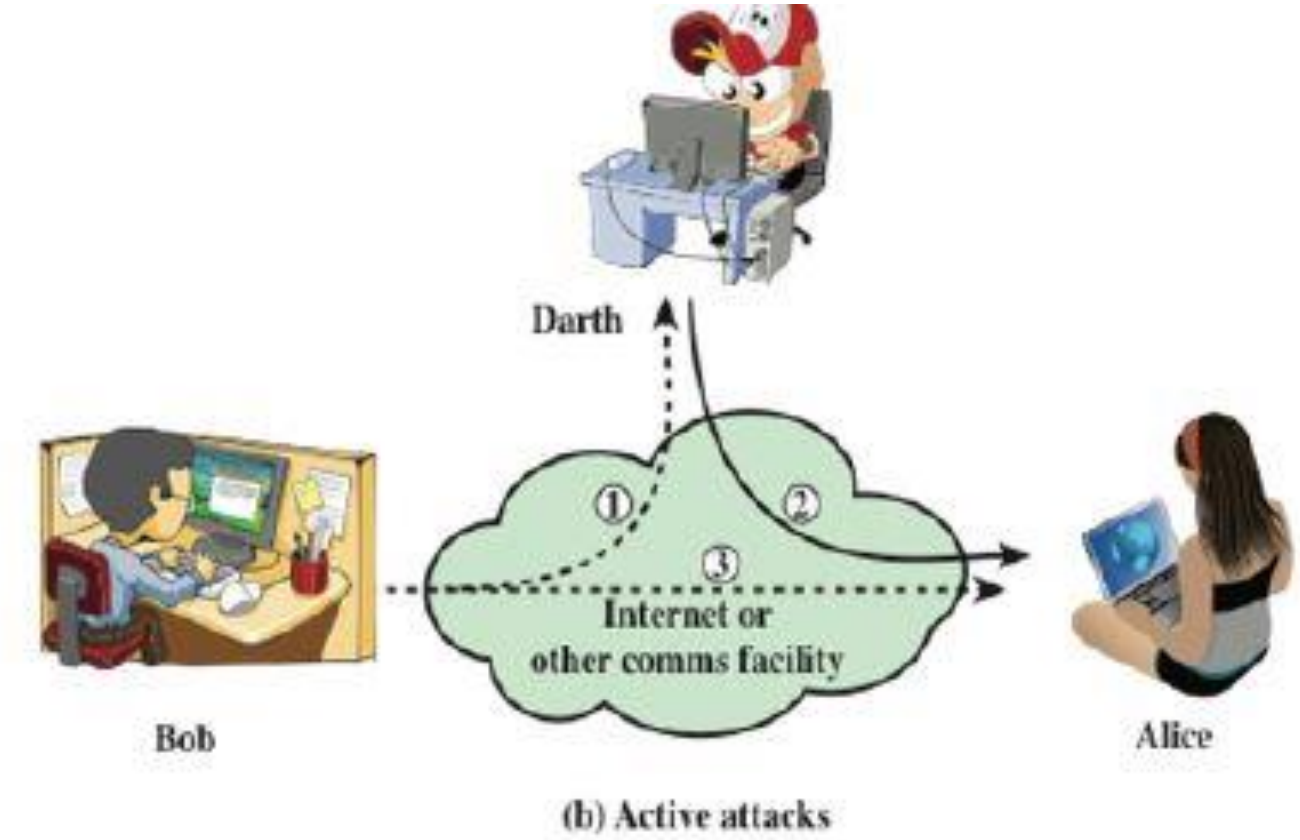


Fig 3: Security Attacks (Courtesy: Cryptography and Network Security by William Stallings)

Security Attacks..

Attacks	Passive/Active	Threatening
Snooping Traffic Analysis	Passive	Confidentiality
Modification Masquerading Replaying Repudiation	Active	Integrity
Denial of Service	Active	Availability

Security Services

- A processing or communication service provided by a system to give a specific kind of protection to system resources
- Categorized into five categories
  - Authentication
  - Access Control
  - Data Confidentiality
  - Data Integrity
  - Nonrepudiation

Authentication

- Concerned with assuring that a communication is authentic
  - In the case of a single message, assures the recipient that the message is from the source that it claims to be from
  - In the case of ongoing interaction, assures the two entities are authentic and that the connection is not interfered with in such a way that a third party can masquerade as one of the two legitimate parties
  - Two specific authentication services are defined in X.800 namely peer entity authentication and data origin authentication

Access Control

- The ability to limit and control the access to host systems and applications via communications links
  - ‘access’ term with very broad and can involve reading, writing, modifying, executing programs etc.
- To achieve this, each entity trying to gain access must first be identified, or authenticated, so that access rights can be tailored to the individual

Data Confidentiality

- The protection of transmitted data from passive attacks
  - Broadest service protects all user data transmitted between two users over a period of time
  - Narrower forms of service includes the protection of a single message or even specific fields within a message
- The protection of traffic flow from analysis
  - This requires that an attacker not be able to observe the source and destination, frequency, length, or other characteristics of the traffic on a communications facility

Data Integrity

- Can apply to a stream of messages, a single message or selected fields within a message
  - **Connection-oriented Integrity service**
    - deal with a stream of messages,
      - assures that messages are received as sent with no duplication, insertion, modification, reordering or replay.
  - **Connection-less Integrity service**
    - deals with individual messages without regard to larger context,
      - generally, provides protection against message modification only

Non repudiation

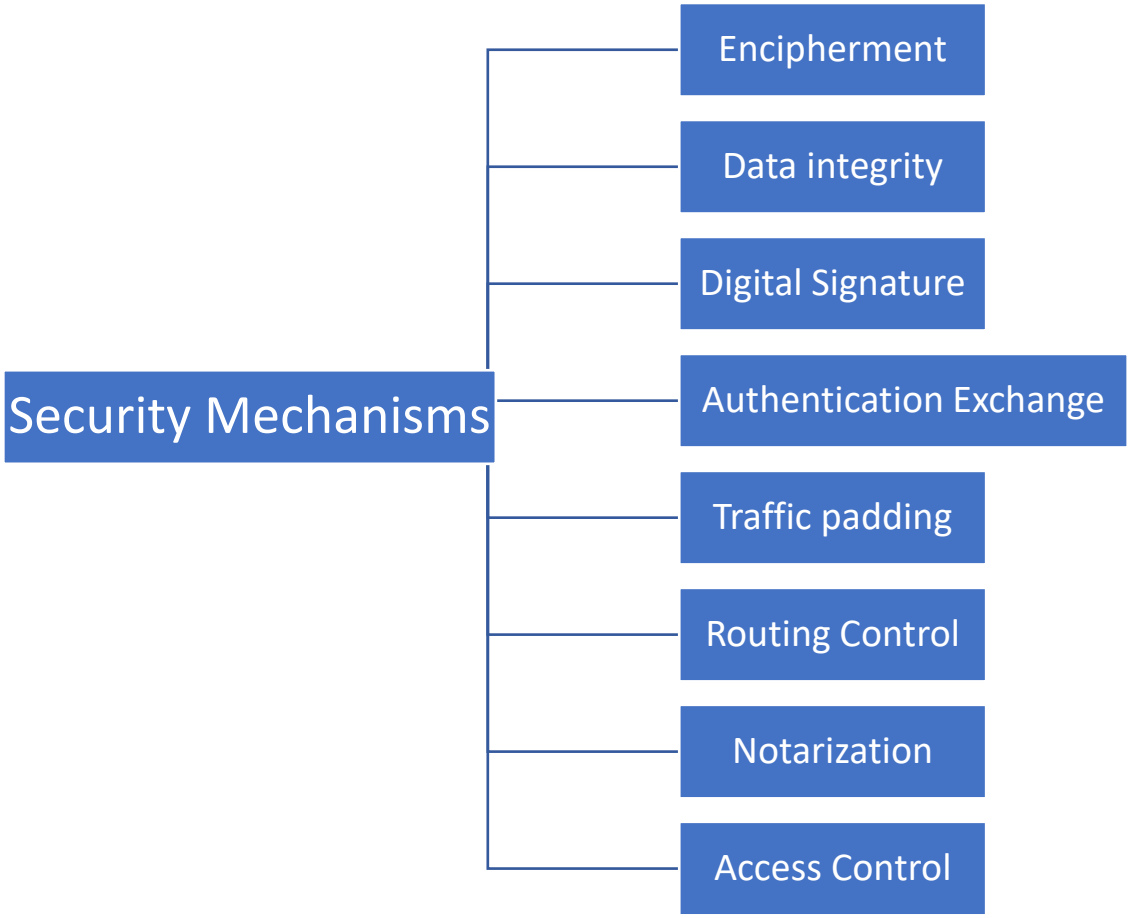
- Prevents either sender or receiver from denying a transmitted message
- In non-repudiation with proof of origin
  - receiver can prove identity of sender if sender denies
- In non-repudiation with proof of delivery
  - sender can prove identity of receiver if receiver denies

Availability

- Protects a system to ensure its availability
- This service addresses the security concerns raised by denial-of-service attacks
- It depends on proper management and control of system resources and thus depends on access control service and other security services

Security Mechanisms

ITU-T (X.800) recommends security mechanisms to provide security services



Security Mechanisms..

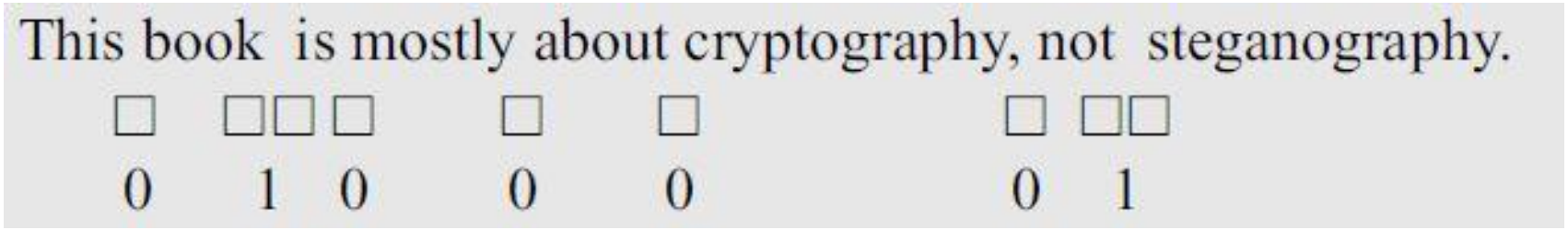
- Encipherment
  - hiding or covering data
  - two techniques
    - cryptography
    - steganography

Security Mechanisms..

- Cryptography
  - Cryptography, a word with Greek origins, means “secret writing”
  - involves three distinct mechanisms:
    - symmetric-key encipherment
      - involves single secret key for both encryption and decryption.
    - asymmetric-key encipherment
      - two keys: public key and private key
      - sender encrypts message using receiver’s public key
      - receiver decrypts message using own private key
    - hashing
      - fixed-length message digest is created out of a variable-length message
      - digest is normally much smaller than the message
      - used to provide checkvalues

Security Mechanisms..

- Steganography
  - conceal the message itself by covering it with something else.
  - For example, text cover where the cover of secret data can be text
    - Assume single space between words to represent the binary digit 0 and double space to represent binary digit 1
      - hides the 8-bit binary representation of the letter A in ASCII code (01000001)



Security Mechanisms..

- Data Integrity
  - sender appends checkvalue
    - that has been created by specific process from data itself
  - receiver receives data and checkvalue
    - generates new checkvalue and compares with received checkvalue
      - if checkvalues are same then integrity is preserved

Security Mechanisms..

- Digital Signature
  - sender electronically sign data and receiver electronically verifies the signature
  - sender uses his/her own private key to sign data
  - receiver verifies signature using sender's public key
- Authentication Exchange
  - two entities exchange some message to prove their identity
- Traffic Padding
  - inserting some bogus data into data traffic to prevent adversary's attempt to use traffic analysis

Security Mechanisms..

- Routing Control
  - selecting and continuously changing different available routes between sender and receiver
    - to prevent eavesdropping on particular route
- Notarization
  - selecting trusted third party
    - to control communication between two entities
  - for example, to prevent repudiation
    - receiver can involve trusted party to store the sender request in order to prevent sender from later denying that she has made such a request

Security Mechanisms

- Access Control
  - Access control uses methods to prove that a user has access right to the data or resources owned by a system.

Relation between Services and Mechanisms

Security Service	Security Mechanisms
Data Confidentiality	Encipherment and routing control
Data Integrity	Encipherment, digital signature, data integrity
Authentication	Encipherment, digital signature, authentication exchanges
Nonrepudiation	Digital signature, data integrity, and notarization
Access control	Access control mechanism

Fundamental Security Design Principles

- Despite years of research and development
  - not possible to develop security design and implementation techniques
    - that systematically exclude security flaws and prevent all unauthorized actions.
- It is useful to have a set of widely agreed design principles that can guide the development of protection mechanisms

Fundamental Security Design Principles

- Economy of mechanism
- Fail-safe defaults
- Complete mediation
- Open design
- Separation of privilege
- Least privilege
- Least common mechanism
- Psychological acceptability
- Isolation
- Encapsulation
- Modularity
- Layering
- Least astonishment

Fundamental Security Design Principles..

- Economy of mechanism
  - Means that the design of security measures embodied in both hardware and software should be as simple and small as possible
  - Relatively simple, small design is easier to test and verify thoroughly
  - With a complex design, there are many more opportunities for an adversary to discover subtle weaknesses to exploit that may be difficult to spot ahead of time

Fundamental Security Design Principles..

- Fail-safe defaults
  - Means that access decisions should be based on permission rather than exclusion
  - The default situation is lack of access,
    - and the protection scheme identifies conditions under which access is permitted
  - Design or implementation mistake in a mechanism that explicitly excludes access tends to fail by allowing access, a failure that may long go unnoticed in normal use.
    - Most file access systems and virtually all protected services on client/server work in this way

Fundamental Security Design Principles..

- Complete mediation
  - Means that every access must be checked against the access control mechanism
    - Systems should not rely on access decisions retrieved from a cache
  - To fully implement this, every time a user reads a field or record in a file, or a data item in a database, the system must exercise access control
    - This resource-intensive approach is rarely used

Fundamental Security Design Principles..

- Open design
  - Means that the design of a security mechanism should be open rather than secret
  - Although encryption keys must be secret, encryption algorithms should be open to public scrutiny
    - So that algorithms can be reviewed by many experts, and users can have high confidence in them.
      - This is the philosophy behind the NIST program of standardizing encryption and hash algorithms

Fundamental Security Design Principles..

- Separation of privilege
  - Defined as a practice in which multiple privilege attributes are required to achieve access to a restricted resource
  - Multifactor user authentication is an example which requires the use of multiple techniques, such as a password and a smart card, to authorize a user

Fundamental Security Design Principles..

- Least privilege
  - Means that every process and every user of the system should operate using the least set of privileges necessary to perform the task
  - An example of the use of this principle is role-based access control; the system security policy can identify and define the various roles of users or processes and each role is assigned only those permissions needed to perform its functions

Fundamental Security Design Principles..

- Least common mechanism
  - Means that the design should minimize the functions shared by different users, providing mutual security
  - This principle helps reduce the number of unintended communication paths
    - and reduces the amount of hardware and software on which all users depend,
      - thus, making it easier to verify if there are any undesirable security implications

Fundamental Security Design Principles..

- Psychological acceptability
  - Implies that the security mechanisms should not interfere unduly with the work of users, while at the same time meeting the needs of those who authorize access
  - If security mechanisms hinder the usability or accessibility of resources, then users may opt to turn off those mechanisms.
  - Where possible, security mechanisms should be transparent to the users of the system or, at most, introduce minimal obstruction
  - In addition to not being intrusive or burdensome, security procedures must reflect the user's mental model of protection

Fundamental Security Design Principles..

- Isolation
  - Public access systems should be isolated from critical resources to prevent disclosure or tampering
  - Processes and files of individual users should be isolated from one another except where it is explicitly desired
  - Security mechanisms should be isolated in the sense of preventing access to those mechanisms
    - For example, protect cryptographic software
      - from tampering and the keys from replacement or disclosure.

Fundamental Security Design Principles..

- Encapsulation
  - Can be viewed as a specific form of isolation based on object-oriented functionality
  - Protection is provided by
    - encapsulating a collection of procedures and data objects in a domain of its own
      - so that the internal structure of a data object is accessible only to the procedures of the protected subsystem
        - procedures may be called only at designated domain entry points.

Fundamental Security Design Principles..

- Modularity
  - Refers both to the development of security functions as separate, protected modules and
    - to the use of a modular architecture for mechanism design and implementation
      - Use of modular architecture ensures that
        - each security mechanism should be able to support migration to new technology
        - or upgrade of new features without requiring an entire system redesign.

Fundamental Security Design Principles..

- Layering
  - Refers to the use of multiple, overlapping protection approaches in information systems
  - The failure or circumvention of any individual protection approach will not leave the system unprotected

Fundamental Security Design Principles..

- Least astonishment
  - Means that a program or user interface should always respond in the way that is least likely to astonish the user
  - The mechanism for authorization should be transparent enough to a user that the user has a good intuitive understanding of how the security goals map to the provided security mechanism

Attack Surfaces

- Attack Surface
  - consists of the reachable and exploitable vulnerabilities in a system
  - categorized into following:
    1) Network attack surface:
       - vulnerabilities over an enterprise network, wide-area network, or the Internet.
         - for instance, denial-of-service attack, disruption of communications links,
    2) Software attack surface:
       - vulnerabilities in application, utility, or operating system code.

Attack Surfaces..

- Attack Surface
    3) Human attack surface
        - vulnerabilities created by personnel or outsiders, such as social engineering, human error, and trusted insiders

Attack Tree

- Attack tree represents
  - branching, hierarchical data structure
    - that represents a set of potential techniques to exploit security vulnerabilities
- Root represents
  - goal of attack
- Subnodes represent
  - ways that an attacker could reach that goal of attack
- Leaf node represent
  - different ways to initiate an attack

Attack Tree..

- In context to Attack Tree for Internet Banking Authentication
  - Three entities are involved in authentication
    - **User terminal and user (UT/U)**
      - attacks target the user equipment,
        - such as smartcards or tokens involved etc.
    - **Communications channel (CC)**
      - attack focuses on communication links.
    - **Internet banking server (IBS)**
      - attacks against servers that host the Internet banking application
  - Root node
    - represents objective of attacker
  - Shaded nodes
    - represent events that comprise the attacks

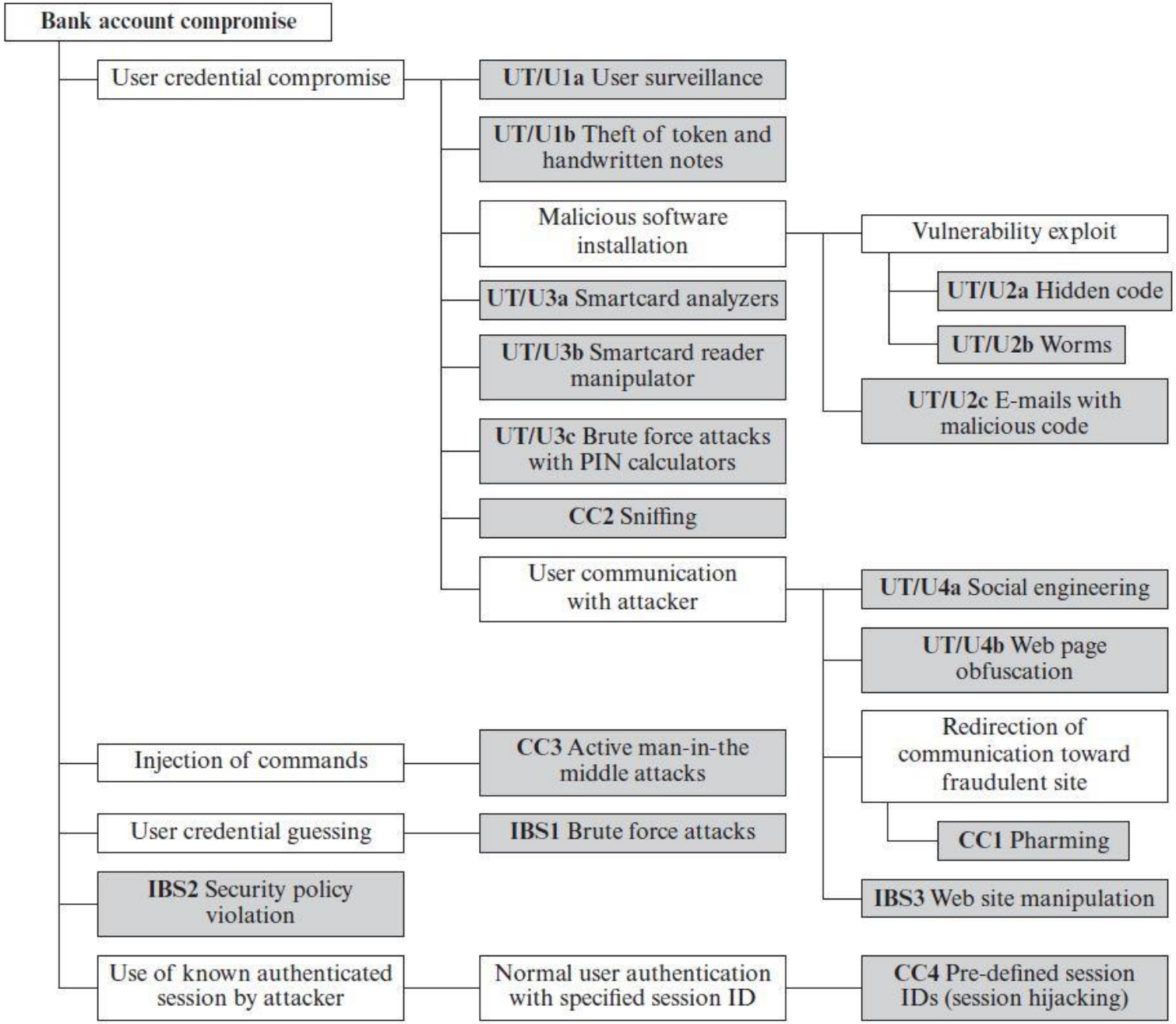


Fig 4: An Attack Tree for Internet Banking Authentication

Attack Tree..

- Overall five attack strategies are identified:
  1. User credential compromise
     - procedural attacks, such as monitoring a user's action to observe a PIN or other credential, or theft of the user's token
       - or embed malicious software to compromise the user's login and password
  2. Injection of commands
     - attacker is able to intercept communication between the UT and the IBS
  3. User credential guessing
     - brute force attacks against some banking authentication schemes are feasible by sending random usernames and passwords.

Attack Tree..

4. Security policy violation
   - violating the bank's security policy
     - in combination with weak access control and logging mechanisms
5. Use of known authenticated session
   - persuades or forces the user to connect to the IBS with a preset session ID
   - once user authenticates to the server, the attacker may utilize the known session ID to send packets to the IBS, spoofing the user's identity.

Model for Network Security

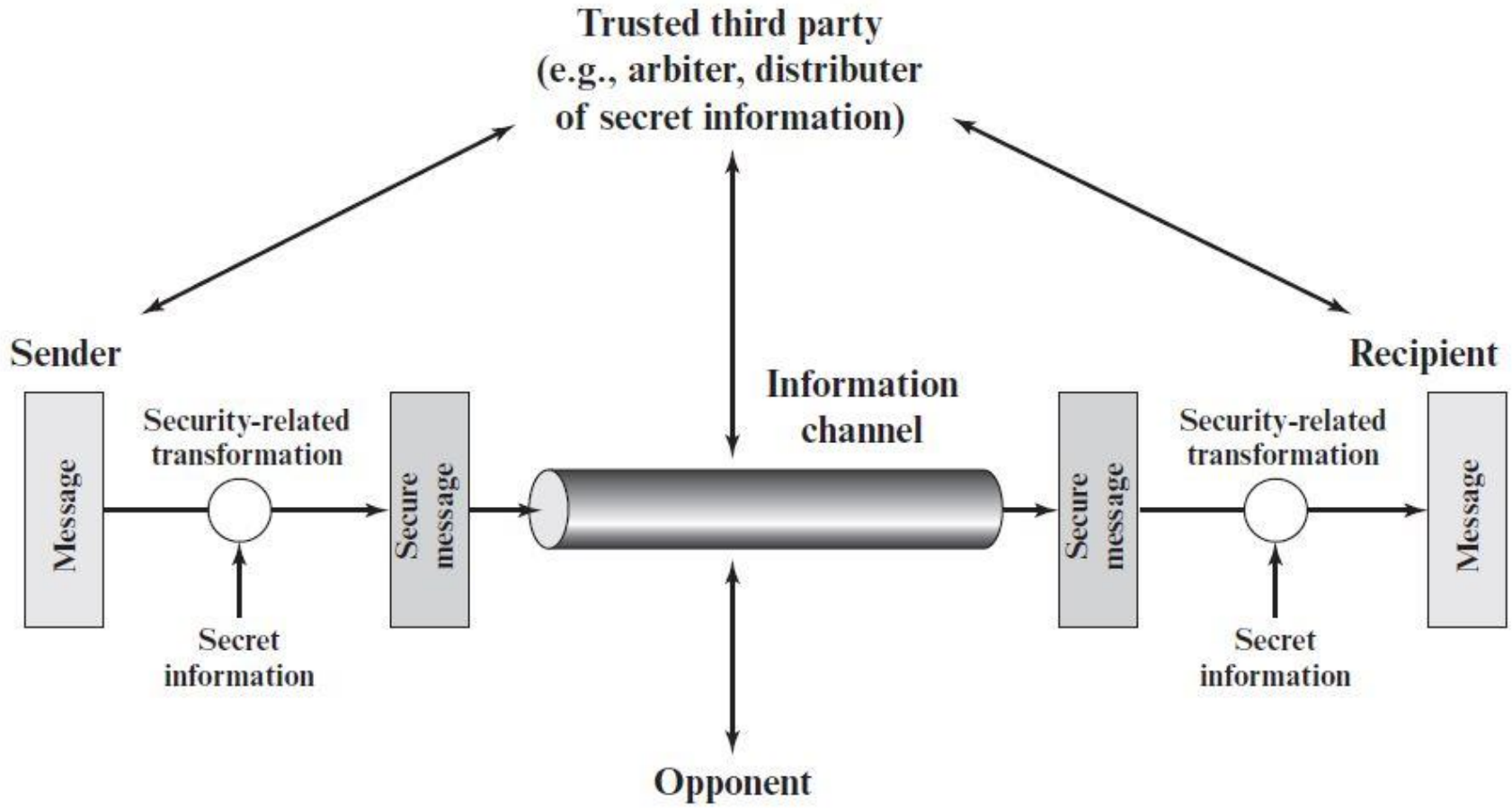


Fig 5: Model for Network Security

Model for Network Security..

- The general model depicts that four basic tasks are included in designing particular security service:
  1. Design an **algorithm for performing the security-related transformation**. The algorithm should be such that an opponent cannot defeat its purpose.
  2. Generate the **secret information** to be used with the algorithm.
  3. Develop **methods for distribution and sharing** of the secret information.
  4. Specify a **protocol** to be used by the two principals that make use of the security algorithm and the secret information to achieve a particular security service.